Attaque XSS

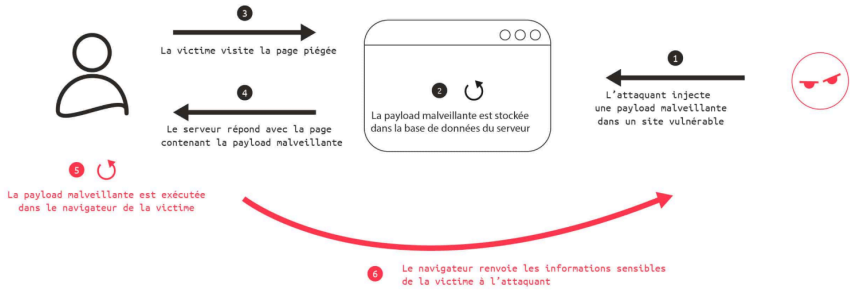
Écrit par Valentin CEMON

Une attaque XSS est une faille de sécurité qui permet à un attaquant d'injecter du code malveillant dans un site Web qui peut sembler sûr.

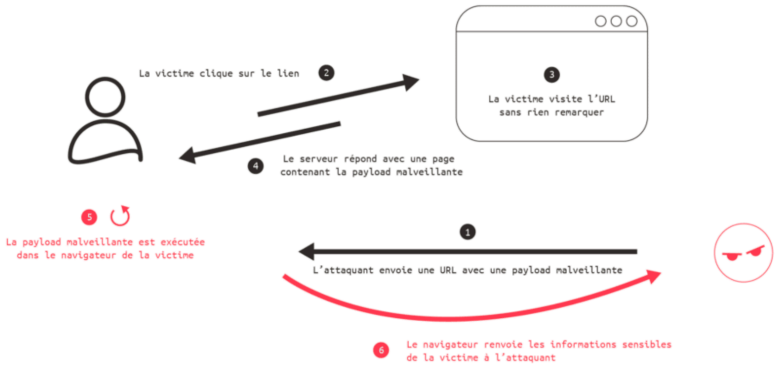
Ce code est ensuite exécuté par le navigateur de la victime, lui permettant de voler des informations sensibles, de détourner des seessions, de dégrader l'expérience utilisateur et plus encore.

On en compte 3 types :

- XSS stocké : Le code malveillant est stocké de manière permanente sur le serveur, comme dans un commentaire ou une publication de forum



- XSS Réflété : Le code malveillant est renvoyé vers le navigateur de la victime via une URL ou un paramètre de requête.



- XSS DOM-based : Le code malveillant est injecté directement dans le Document Object Model (DOM) du navigateur de la victime. Une attaque DOM-based peut cependant aussi être stockée ou reflétée.

Mesure de prévention

Pour prévenir les attaques XSS, il faut partir du principe que les données reçues par une application web ne peuvent pas être considérées comme « toujours » sûres.

Il est donc important d'implémenter des mesures de protection pour traiter toutes les données venant de l'extérieur. Ainsi, tout contenu doit être filtré, validé et encodé avant d'être utilisé par l'application.

- **Encoder (échapper) les données en entrée et en sortie**: L'encodage (ou échappement) des données en entrée ou en sortie reste la mesure de sécurité essentielle pour prévenir les attaques XSS. L'objectif rappelons-le est d'empêcher l'exécution d'un code malveillant dans le navigateur des utilisateurs. Pour ce faire, il s'agit de remplacer les caractères spéciaux par des valeurs encodées, de manière à ce que toute donnée saisie par un utilisateur soit traitée (reçue et interprétée) comme du texte, plutôt que comme du code.
- **Filtrer les données reçues côté client**: Une autre mesure de prévention contre une attaque XSS est le filtrage des données reçues côté client. Cela signifie que l'ensemble des données doit passer par un filtre qui élimine les caractères dangereux comme la balise `<script>`, les gestionnaires d'événements HTML comme `onActivate()`, `onClick()`, les éléments JavaScript, etc. Comme pour l'encodage, les données peuvent être filtrées en entrée et/ou en sortie. Filtrer en entrée consiste, à supprimer des mots clés potentiellement dangereux des entrées utilisateurs, tandis que le filtrage en sortie est appliqué aux données qui sont renvoyées dans la page web de réponse. Cette méthode fonctionne essentiellement pour les attaques XSS stockées
- **Valider les entrées utilisateurs**: Valider les entrées utilisateurs est également une mesure de sécurité pour contrer les attaques XSS. L'idée ici est de faire en sorte que tous les champs de saisie correspondent au type de données attendu.

  Par exemple, pour un champ de saisie d'un numéro de téléphone, il doit être impossible pour un utilisateur d'insérer du texte. De la même manière, les balises HTML n'étant pas légitimes dans ce type de formulaire, elles doivent être validées pour empêcher les attaquants de soumettre des scripts malveillants.
- **Utiliser le standard CSP (Content Security Policy)**:Pour exploiter une faille XSS, un attaquant peut contourner le navigateur d'un utilisateur et injecter un script malveillant à partir de sources externes, de manière à ce que le navigateur ne soit pas capable de distinguer les scripts malveillants des légitimes.

  Pour réduire le risque de ce type d'exploitation XSS (et tout type d'injection de code), Mozilla a développé un mécanisme de sécurité connu sous le nom de Content Security Policy (CSP). Ce standard de sécurité permet de contrôler (restreindre via autorisation) les sources externes (autres sites web) de récupération de données.

  Ainsi, si ce mécanisme est en place, le navigateur sera autorisé à accéder uniquement aux ressources figurant sur la liste blanche, en ignorant tous les autres domaines. Les scripts injectés ne seront donc pas exécutés même si un attaquant découvre des possibilités d'injection XSS.